

LAB 09

SecureBank - Uçtan Uca BT Denetimi

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Senior IT Auditor

1. HİKÂYE

Sektör Bireysel ve ticari bankacılık	Ölçek 11.500 çalışan
Uygulama LendOne kredi karar platformu	Entegrasyon Core banking, kredi bürosu, veri ambarı, mobil kanal

SecureBank Denetim Başkanı sizi LendOne uygulamasının uçtan uca denetimine atamıştır. Uygulama yıllık 4,2 milyon kredi başvurusunu işler ve otomatik karar üretir. Geçen yıl model değişiklikleri, ayrıcalıklı erişim ve veri kalitesi farklı ekiplerce incelenmiş ancak uygulama bütünüyle denetlenmemiştir. İş birimi düşük hata oranını öne çıkarırken Risk Yönetimi manuel override kullanımındaki artıştan endişelidir.

2. SİZE VERİLEN GÖREV

Denetimin kapsamını, risk değerlendirmesini, kontrol seçimini, kanıt stratejisini ve raporlanabilir sonuçlarını kıdemli denetçi bakışıyla oluşturun. Kapsamı sınırsız genişletmeyin.

3. OLAYLAR VE KANITLAR

E-01 | Süreç akışı

Başvuru mobil/şubeden alınır; müşteri verisi doğrulanır; kredi bürosu sorgulanır; karar motoru skor üretir; belirli eşiklerde analist override yapabilir; onay core bankacılığa gönderilir.

E-02 | Risk göstergeleri

Başarısız entegrasyon %0,3; manuel override geçen yıl %2,1, bu yıl %6,8; production incident 4; kritik zafiyet 0; yüksek zafiyet 7. İş birimi override artışını yeni kampanyaya bağlar.

E-03 | Erişim

42 kredi analisti override yetkilidir. Limit değişikliği için iki onay gerekir. Beş analistin hem kural görüntüleme hem override yetkisi vardır. Kural değiştirme yalnızca Model Yönetimi ekibindedir.

E-04 | Değişiklik örneği

CR-441 kampanya skoru: iş onayı var, bağımsız model doğrulama var, UAT var. CR-447 acil eşik değişikliği: risk yöneticisi sözlü onay, sonradan ticket; etki analizi yok; iki gün sonra geri alınmış.

LAB 09

SecureBank - Uçtan Uca BT Denetimi

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Senior IT Auditor

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Veri bütünlüğü

Günlük mutabakat toplam kayıt sayısını karşılaştırır. Alan bazlı doğrulama yalnızca müşteri kimliği ve tutar için vardır. Geçen ay 3.214 kayıta gelir alanı boş, sistem varsayılan değer kullanmıştır.

E-06 | Loglama

Override yapan kullanıcı, eski/yeni karar ve zaman damgası kaydedilir. Gerekçe serbest metindir. Örneklenen 30 override'ın 9'unda 'müşteri uygun' yazmaktadır. Aylık review toplam oran üzerinden yapılır.

E-07 | Önceki güvence çalışmaları

Sızma testi dış açıklıkta kritik bulgu bulmamıştır. Model doğrulama istatistiksel performansı uygun bulmuştur. Bu raporların hiçbirisi kullanıcı erişimi, override gerekçesi veya kaynak veri bütünlüğünü kapsamamıştır.

E-08 | Kaynak kısıtı

Denetim için 30 iş günü ve iki denetçi ayrılmıştır. Başkan, ilk sonuçları 10. günde istemektedir. Üretim verisine doğrudan erişim verilmeyecek, raporlar ekip tarafından üretilecektir.

4. ÖĞRENCİNİN GÖREVLERİ

- Denetim amacı, kapsam içi ve kapsam dışı alanları tanımlayın.
- Uygulamanın en önemli risklerini süreç adımlarıyla eşleştirin.
- Kontrol evreninden test edeceğiniz kontrolleri ve nedenlerini seçin.
- Ekip tarafından üretilen raporların güvenilirliğini nasıl doğrularsınız?
- Override ve veri kalitesi için popülasyon/örneklem yaklaşımı kurun.
- Önceki güvence raporlarına ne ölçüde dayanacağınızı açıklayın.
10. gün ara raporu ile final raporu için öncelikleri belirleyin.
- En güçlü bulgu adayını profesyonel formatta yazın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Denetim planlama notu
- Risk-kontrol-test matrisi
- Kanıt ve örneklem stratejisi
- En az 2 audit observation
- Yönetici özeti ve kapsam sınırlamaları

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com
adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası